BÀI TẬP TÌNH HUỐNG

Chủ đề: *Có tồn tại an toàn thông tin tuyệt đối hay không?*

Câu 1 (4 điểm): ***Phân tích các hiểm họa và các điểm yếu còn tồn tại của hệ thống LMS***

Hệ thống quản lý đào tạo trực tuyến (LMS) của trường đại học phục vụ nhiều nghiệp vụ quan trọng như quản lý điểm, học liệu số và thi trực tuyến. Mặc dù nhà trường đã đầu tư nhiều biện pháp bảo mật, hệ thống vẫn có thể đối mặt với các hiểm họa và tồn tại những điểm yếu sau:

1. Các hiểm họa có thể xảy ra

- Thứ nhất, **hiểm họa lộ thông tin tài khoản người dùng**.
  Trên thực tế, sinh viên thường có thói quen đặt mật khẩu đơn giản, sử dụng chung mật khẩu cho nhiều hệ thống hoặc đăng nhập trên máy tính công cộng. Điều này tạo điều kiện cho kẻ xấu đánh cắp tài khoản, dẫn đến việc lộ điểm số hoặc dữ liệu cá nhân. Thực tế đã có nhiều trường hợp sinh viên bị mất tài khoản LMS do bị lừa qua email giả mạo (phishing).
- Thứ hai, **tấn công mạng từ bên ngoài**.
  Hệ thống LMS hoạt động trên môi trường Internet nên dễ trở thành mục tiêu của các cuộc tấn công như tấn công từ chối dịch vụ (DDoS), làm hệ thống không thể truy cập được trong một số thời điểm cao điểm như lúc thi trực tuyến hoặc xem điểm.
- Thứ ba, **nguy cơ nhiễm mã độc và ransomware**.
  Dù hệ thống có phần mềm chống mã độc, nhưng nếu không cập nhật thường xuyên hoặc người quản trị vô tình mở file độc hại, mã độc vẫn có thể xâm nhập, gây mất dữ liệu hoặc làm gián đoạn hoạt động của hệ thống.
- Thứ tư, **rủi ro từ con người bên trong hệ thống**.
  Giảng viên, cán bộ quản trị nếu phân quyền chưa chặt chẽ hoặc thao tác sai cũng có thể làm lộ dữ liệu quan trọng của nhà trường.

❖ ***Ghi chú:***

Ransomware *là một loại virus được mã hóa, được Bộ Tư pháp Hoa Kỳ xem là mô hình hiện đại của tội phạm mạng với nguy cơ gây tổn thương hệ thống mạng toàn cầu. Khi ransomware lây nhiễm vào máy tính, nó sẽ mã hóa hoặc chặn những truy cập dữ liệu trên đĩa. Để hoạt động bình thường trở lại, người dùng phải chuyển tiền vào tài khoản mới gỡ được ransomware.*

Phishing (Tấn công giả mạo) *là hình thức tấn công mạng mà kẻ tấn công giả mạo thành một đơn vị uy tín để lừa đảo người dùng cung cấp thông tin cá nhân cho chúng.*

Tấn công DDoS (Distributed Denial of Service) *là hình thức tấn công từ chối dịch vụ phân tán, sử dụng hàng loạt thiết bị (botnet) gửi lưu lượng truy cập ảo khổng lồ đến mục tiêu, khiến máy chủ quá tải và ngừng hoạt động.*

2. Các điểm yếu còn tồn tại của hệ thống

- **Yếu tố con người**: Đây là điểm yếu lớn nhất. Dù hệ thống kỹ thuật tốt nhưng người dùng thiếu ý thức bảo mật vẫn làm giảm mức độ an toàn.
- **Tính sẵn sàng chưa được đảm bảo tuyệt đối**: Có UPS nhưng vẫn có thể xảy ra sự cố mạng, phần cứng hoặc bị tấn công DDoS.
- **Chi phí bảo mật ngày càng tăng**: Đầu tư bảo mật không có điểm dừng vì các mối đe dọa luôn thay đổi.
- **Hệ thống phụ thuộc vào cấu hình và vận hành**: Chỉ cần cấu hình firewall sai hoặc chậm vá lỗi cũng có thể tạo ra lỗ hổng.

❖ ***Ghi chú:***

Bộ lưu điện (UPS - Uninterruptible Power Supply) *là thiết bị điện tử dùng để lưu trữ điện năng dự phòng và cung cấp nguồn điện liên tục cho các thiết bị khi nguồn điện chính bị gián đoạn hoặc mất điện.*

Câu 2 (3 điểm): Đánh giá hệ thống có đạt mức an toàn thông tin tuyệt đối hay không? Vì sao?

✓ Hệ thống LMS **không đạt được mức an toàn thông tin tuyệt đối**.

Nguyên nhân là vì **an toàn thông tin tuyệt đối không tồn tại trong thực tế**. Mặc dù nhà trường đã áp dụng nhiều biện pháp bảo mật như firewall, mã hóa cơ sở dữ liệu và sao lưu định kỳ, nhưng hệ thống vẫn xảy ra hiện tượng lộ tài khoản và không truy cập được trong một số thời điểm. Điều này cho thấy vẫn tồn tại rủi ro và lỗ hổng.

Bên cạnh đó, các hình thức tấn công mạng ngày càng tinh vi, trong khi con người luôn có khả năng mắc sai sót. Vì vậy, không một hệ thống nào có thể đảm bảo an toàn 100% trong mọi tình huống.

Câu 3 (3 điểm): Đề xuất quan điểm đúng đắn về mục tiêu đảm bảo an toàn thông tin

➢ Quan điểm đúng đắn trong đảm bảo ***an toàn thông tin*** cho hệ thống ***LMS*** là:

✓ *Không hướng tới an toàn tuyệt đối, mà hướng tới giảm thiểu rủi ro và đảm bảo hệ thống hoạt động ổn định, an toàn ở mức chấp nhận được.*

Cụ thể:

- Kết hợp **giải pháp kỹ thuật** (firewall, mã hóa, sao lưu, xác thực đa yếu tố) với **giải pháp con người** (đào tạo nhận thức an toàn thông tin cho sinh viên và giảng viên).
- Cân bằng giữa **bảo mật, chi phí và hiệu quả sử dụng**, tránh đầu tư dàn trải nhưng không hiệu quả.
- Thường xuyên **đánh giá rủi ro, kiểm tra và nâng cấp hệ thống** để kịp thời phát hiện lỗ hổng.
- Chuẩn bị **kế hoạch ứng phó sự cố**, đảm bảo khi xảy ra tấn công hoặc sự cố, hệ thống có thể nhanh chóng phục hồi.

❖ ***Ghi chú:***

Firewall (tường lửa) *là rào chắn mà một số cá nhân, tổ chức, doanh nghiệp, cơ quan nhà nước lập ra nhằm ngăn chặn các truy cập thông tin không mong muốn từ ngoài vào hệ thống mạng nội bộ.*

👉 **Kết luận**: An toàn thông tin là một quá trình liên tục, không phải là trạng thái cố định. Hệ thống LMS chỉ có thể đạt được mức an toàn tương đối, phù hợp với điều kiện thực tế và nhu cầu sử dụng của nhà trường.